



File No.: EXP202208709

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant), on May 6, 2022, filed a complaint with the Spanish Agency for Data Protection. The complaint is directed against the STATE AGENCY FOR LABOR INSPECTION AND SOCIAL SECURITY, with NIF Q2802489A, (hereinafter, the respondent). The reasons on which the complaint is based are as follows:

The claimant states that the Consortium for Labor Inspection and Social Security of Catalonia has provided a former employee of the company Tapioca Healthy Food, S.L., where the claimant currently works, with her personal data along with a Record of Settlement of Contributions to Social Security, Unemployment, Wage Guarantee Fund, and Vocational Training, to inform him of the amounts that the company must pay.

The claimant asserts that she has never authorized the sending of her personal data or nominal relationship and that, although it is a record with the nature of provisional settlement containing information about all workers, only this person has received the information. She believes that these practices violate the current legislation on the protection of personal data.

Along with the complaint, she provides a copy of the notification issued on February 25, 2022, by the State Agency for Labor Inspection and Social Security, addressed to the aforementioned worker, by which the Record of Settlement of Contributions to Social Security, Unemployment, Wage Guarantee Fund, and Vocational Training is sent, in accordance with the provisions of Article 40 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and a nominal list of workers which includes the data of the affiliation number (NAF) and DNI, both partially anonymized, name and surname along with their contribution data.

SECOND: On August 16, 2022, in accordance with Article 65 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the complaint filed by the claimant was admitted for processing.

THIRD: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

ENTITIES UNDER INVESTIGATION

During the present proceedings, the following entities have been investigated:

PROVINCIAL INSPECTION OF LABOR AND SOCIAL SECURITY OF BARCELONA
with CIF Q0802279J and address at TRAVESSERA E GRÀCIA 303-311 08025
BARCELONA.

RESULT OF THE INVESTIGATION PROCEEDINGS

☐ The Consortium "Labor and Social Security Inspection in Catalonia" is established by Resolution of May 4, 2010, of the Technical General Secretariat, which publishes the Collaboration Agreement between the Ministry of Labor and Immigration and the Department of Labor of the Generalitat of Catalonia.

☐ Article 40 of Law 39/2015, of October 1, on the Common Administrative Procedure

of Public Administrations (hereinafter, LPACAP) in relation to Notification states:

“1. The body that issues resolutions and administrative acts shall notify the interested parties whose rights and interests are affected by them, in the terms provided in the following articles... 5. Public Administrations may adopt the measures they deem necessary for the protection of personal data contained in the resolutions and administrative acts, when these are addressed to more than one interested party.”

On September 22, 2022, information was requested from the responding party, and from the response received, it is inferred:

☐ Article 33.1 of the General Regulation on Procedures for the Imposition of Sanctions for Social Order Violations and for Liquidation Files of Social Security Contributions, approved by Royal Decree 928/1998, of May 14, imposes on the Inspection the obligation to notify the liquidation report to the interested parties, with the specification that “if it affects a group of workers, the notification shall be made to their unitary representation or, failing that, to the first of those affected in alphabetical order of surnames and name.”

The claiming party states that B.B.B. is the one who heads, in alphabetical order of surnames, the list of interested parties.

A copy of the content of the aforementioned article is attached in a diligence (D NOTIFICA).

☐ The copy of the Report sent to the workers and provided by both the claiming party and the responding party contains the name and ID number of the claimant, as interviewed by the labor inspector, and on another page of the Report, the name, night hours worked, and total amount owed of several workers, including the claimant. At the end of the Report, a nominal list of workers is attached with the data of Affiliation Number (NAF) and ID number, both partially anonymized, and name and surname along with contribution data.

In this regard, the responding party states that the anonymization is carried out in accordance with the guidelines on data anonymization contained in the informative note from the General Subdirectorate of Institutional Relations and Assistance.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/19

Technical Report of the State Agency for Labor Inspection and Social Security, sent to the Provincial Inspections on 22/11/21, and a copy of this is attached.

The attached copy states:

"Regarding the liquidation records, the following was indicated:

Article 32.1 of the General Regulation on Procedures for the Imposition of Sanctions for Social Order Violations and for the Liquidation Files of Social Security Contributions, provides that 'the liquidation records shall contain the following requirements: ... b) Name and surname or corporate name, address, activity, national identity document or tax identification number, the Social Security contribution account code and, where applicable, the identification number of the Special Regime for Self-Employed Workers, of the responsible party or parties....

Therefore, and for reasons of legal certainty aimed at avoiding possible defenselessness, if the responsible party for the debt is a natural person, both their NIF (Tax Identification Number) and their Social Security Number must be reflected if the responsible party is a self-employed worker. This will apply to both the main responsible party and any possible joint responsible party. Regarding the affected workers, the regulatory standard requires the inclusion of a nominal list of affected workers, and to obtain adequate identification and avoid defenselessness, it is necessary to include the Social Security number and/or NIF-NIE. If at least the NAF (Social Security Number) is not indicated in the

nominal list of workers, identification problems may arise in some cases.

With respect to the other natural persons whose activity or testimony is reflected in the record, their correct identification is necessary, but it is not required to reach the level of detail required in cases involving directly affected workers. Considering the principle of data minimization contained in Article 5.1.c) of the GDPR, these persons can be adequately identified by their name and surname and an 'anonymized' identification number similar to what we will see in point III, replacing part of the alphanumeric characters of the document number with asterisks. If subsequently a judicial body requests additional information, there will be no obstacle to providing it (for which the acting party must have recorded the complete information in the internal report).

However, given the requirements of both the LOPDP (Organic Law on Data Protection) for data protection and the requirements regarding the content of the liquidation records provided by the General Regulation on Procedures for the Imposition of Sanctions for Social Order Violations and for the Liquidation Files of Social Security Contributions, it is estimated that compliance with both regulations is possible as long as:

a) In the body of the liquidation records, all personal data, both of the affected workers and of any other natural person whose testimony has been considered or is included in the account of the facts, is 'anonymized' in accordance with the provisions of point III of this note (this task must be carried out by the acting party).

b) Two models of the nominal list of workers affected by the liquidation record are prepared, one that will include all data of the affected workers that prevents the responsible party from being defenseless and another, anonymized."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/19

anonymized in accordance with point III of this note, which will be sent to the other subjects distinct from the company as provided by article 33.1. (In this case, the personal data of the NIF/NIE/Passport and NAF will be anonymized in the manner provided in point III).

This document includes an example of anonymization similar to that included in the Minutes.

Furthermore, it also states, "The liquidation minutes will also be notified to the interested workers; if it affects a group of workers, the notification will be made to their unitary representation or, failing that, to the first of those affected in alphabetical order of surnames and first name."

- Regarding the documentation evidencing the security procedures related to the protection of information stored and in transit in accordance with article 21 of the National Security Scheme, the responding party states that the Data Protection Officer informs that in November 2021, measures were adopted in our computer system to anonymize the personal data of the liquidation minutes in accordance with article 22 of Royal Decree 311/2022, of May 3, which regulates the National Security Scheme.

- The Data Protection Officer does not intervene in the procedures or documents of the Labor and Social Security Inspectorate. The responding party states that, regarding this claim concerning documents in non-electronic format and the notification of an administrative act, "the measure adopted by the State Agency regarding the anonymization of the nominal relationships of workers in the liquidation minutes that are to be notified to the workers or their representatives responds to that protection of personal data contained in the resolutions or administrative acts, in accordance with the provisions of article 40.5 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations."

CONCLUSIONS

- Article 33.1 of the General Regulation (approved by Royal Decree 928/1998, of May 14) imposes on the Inspectorate the obligation to notify the liquidation minutes to the interested parties, with the specification that "if it affects a group of workers, the notification will be made to their unitary representation or, failing that, to the first of those affected in alphabetical order of surnames and first

name.” The claiming party states that B.B.B. is the one who heads, in alphabetical order of surnames, the list of interested parties.

- The Minutes contain the name and ID number of the claimant, as interviewed by the labor inspector, and on another page of the Minutes, the name, night hours worked, and total amount owed of several workers, including the claimant. At the end of the Minutes, a nominal list of workers is attached with the data of the Affiliation Number (NAF) and ID number, both partially anonymized, along with names and surnames together with contribution data.

The responding party states that the anonymization is carried out in accordance with the guidelines on data anonymization contained in the informative note from the General Subdirectorate of Institutional Relations and Technical Assistance of the State Agency for Labor and Social Security Inspection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/19

□

In that copy, it is stated verbatim:

“The article 32.1 of the General Regulation provides... regarding the affected workers, the regulatory standard requires including a nominal list of affected workers and to obtain the appropriate identification and avoid defenselessness, it is necessary to include the Social Security number and/or NIF-NIE...”

“...given the requirements of both the LOPDP for data protection and the requirements regarding the content of the liquidation minutes provided by the General Regulation..., it is considered that compliance with both norms is possible provided that: a) In the body of the liquidation minutes, all personal data, both of the affected workers and of any other natural person whose testimony has been taken into account or is included in the account of the facts, is “anonymized,” in accordance with what is provided by point III of this note (this task must be carried out by the acting party).

FOURTH: On April 10, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party, for the alleged infringement of article 5.1.f) of the GDPR and article 32 of the GDPR, classified, respectively, in articles 83.5 and 83.4 of the GDPR. The initiation agreement was sent, in accordance with the rules established in the LPACAP, via electronic notification, having been received on April 10, 2023, as stated in the certificate that is part of the file.

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the accused party submitted a written statement of allegations in which, in summary, it stated that all workers affected by the liquidation minutes hold the status of interested parties in the liquidation procedure as provided in article 4 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, to the extent that these workers may be affected by the decision made therein regarding their rights, present and future, in matters of Social Security.

Therefore, and considering that all these individuals are interested parties in the procedure, they have the right to the corresponding hearing and audience within it and consequently, it is alleged that they could have requested access to the copy of the minutes that was notified to the responsible party, a document in which the complete identifying data appears to avoid defenselessness, so the document was always transmitted to individuals who hold the status of interested parties in the liquidation procedure.

Secondly, it is stated that the aforementioned measures indicated in the informative note constitute an additional precaution to avoid a possible accidental dissemination of information and that it is not recorded that the data were transmitted to a third party but to the interested parties in the procedure, for which reason it requests that the ongoing sanctioning procedure be archived.

SIXTH: On June 29, 2023, a resolution proposal was formulated, in which responses were given to the allegations raised and the imposition of two warning sanctions for non-compliance with the provisions of the articles.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/19

5.1.f) and 32 of the GDPR, and a hearing period of ten working days was granted for the party to submit allegations and present any evidence it deemed appropriate.

SEVENTH: The proposed resolution was duly notified in accordance with the rules established in the LPACAP through electronic notification, accepted by the responding party on July 3, 2023, as evidenced by the certificate in the file.

In view of all that has transpired, the Spanish Agency for Data Protection considers the following facts proven in this procedure,

PROVEN FACTS

FIRST: It is recorded that on May 6, 2022, the complainant filed a complaint with the Spanish Agency for Data Protection, as the responding party had disclosed personal information and data to third parties by notifying a settlement report that contained personal data without anonymization.

SECOND: It is recorded in the file an informative note from the General Sub-Directorate of Institutional Relations and Technical Assistance of the State Agency for Labor and Social Security Inspection, sent to the Provincial Inspections, and automatically incorporated into the corresponding computer application, which states verbatim:

"However, given the requirements of both the LOPDP for data protection and the requirements regarding the content of settlement reports provided by the general regulation on procedures for imposing sanctions for social order violations and for the liquidation files of Social Security contributions, it is deemed possible to comply with both regulations provided that:

a) In the body of the settlement reports, all personal data, both of the affected workers and of any other natural person whose testimony has been taken into account or is included in the account of the facts, is 'anonymized', in accordance with the provisions of point III of this note (this task must be carried out by the acting party). (The underlining is from the AEPD).

b) Two models of nominal lists of affected workers by the settlement report are prepared, one that will include all data of the affected workers that prevents the responsible subject from being left defenseless and another, anonymized in accordance with point III* of this note, which will be sent to the other subjects distinct from the company provided for in Article 33.1. (In this case, the personal data of the NIF/NIE/Passport and NAF will be anonymized in the manner provided in point III)."

THIRD: It is evidenced that the copy of the Settlement Report of Contributions to Social Security, Unemployment, Wage Guarantee Fund, and Vocational Training sent to the workers and provided by both the complainant and the responding party contains, without anonymization, on page 22: the name, surname, and ID number of the complainant, as interviewed by the labor inspector along with the data of four other individuals, and on page 24: name and surname, night hours worked during the period, and total amount owed of several workers, including the complainant.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR, and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

The State Agency for Labor and Social Security Inspection provides a series of public services, for which it processes personal data of its employees and citizens.

It carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR: "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States.

Article 4, paragraph 12 of the GDPR broadly defines "personal data breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of or access to personal data transmitted, stored, or otherwise processed."

In this case, there is a personal data breach under the circumstances indicated above, categorized as a breach of confidentiality, as the responding party has disclosed personal information and data to third parties by notifying a settlement report that contained personal data without anonymization.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/19

According to GT29, a "Breach of confidentiality" occurs when there is an unauthorized or accidental disclosure of personal data, or access to it.

Within the principles of processing provided in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Article 32 of the GDPR, which governs the security of processing.

III

Claims Made Regarding the Initiation Agreement

In response to the claims presented by the defendant entity, the following should be noted:

Firstly, the defendant party alleges that all workers affected by the liquidation act hold the status of interested parties in the liquidation procedure, in accordance with the provisions of Article 4 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, to the extent that these workers may be affected by the decision made therein regarding their present and future rights in matters of Social Security.

Therefore, considering that all these individuals are interested parties in the procedure, they have the right to the corresponding hearing and audience within it, and consequently, it is alleged that they could have requested access to the copy of the act that was notified to the responsible subject, a document in which the complete identifying data appears to avoid defenselessness, so the document was always transmitted to individuals who hold the status of interested parties in the liquidation procedure.

In relation to these arguments, it should be noted, firstly, that in accordance with the indications on data anonymization contained in the informative note from the General Subdirectorate of Institutional Relations and Technical Assistance of the State Agency for Labor and Social Security Inspection, sent to the Provincial Inspections, it states verbatim:

"However, given the requirements of both the LOPDP for data protection and the requirements regarding the content of liquidation acts provided by the General Regulation on procedures for imposing sanctions for social order infringements and for liquidation files of Social Security contributions, it is considered that compliance with both regulations is possible provided that:

b) In the body of the liquidation acts, all personal data, both of the affected workers and of any other natural person whose testimony has been taken into account or appears in the account of the facts, is 'anonymized,' in accordance with the provisions of point III of this note (this task must be performed by the acting party). (The underlining is from the AEPD).

c) Two models of nominal lists of workers affected by the liquidation act are prepared, one that will include all data of the workers.

C/ Jorge Juan, 6

www.aepd.es

affected that prevents the responsible subject from incurring in defenselessness and another, anonymized in accordance with point III* of this note, which will be sent to the other subjects distinct from the company provided for by article 33.1. (In this case, the personal data of the NIF/NIE/Passport and NAF will be anonymized as provided in point III).”

Well, it is evidenced that the copy of the Act sent to the workers and provided by both the claiming party and the responding party contains, without anonymization, on page 22: the name, surname, and DNI of the claimant, as interviewed by the labor inspector along with the data of four other people, and on page 24: name and surname, night hours worked during the period, and total amount owed of several workers, including the claimant. That is to say, this document is not anonymized, containing references that allow the identification of the claiming party and the other workers listed therein.

In the present case, the personal data of the claiming party that appear in the Act of Settlement of Contributions to Social Security, Unemployment, Wage Guarantee Fund, and Vocational Training are not anonymized, allowing the claiming party to be identifiable to persons who know the non-anonymized circumstances.

Furthermore, it should be noted that those interviewed are the same workers who also appear in the nominal list, so it would be contradictory to anonymize the data that appear in the nominal list, as is stated, but not throughout the Settlement Act.

Therefore, it should be noted that article 32 of the GDPR is infringed both if the responsible party does not adopt appropriate technical and organizational measures that guarantee the security of personal data, and if, once established, these measures are not observed.

In this regard, it is important to emphasize that data will be considered anonymized to the extent that there is no reasonable probability that any person could identify the individual in the data set.

The process of anonymization aims to eliminate or minimize the risks of re-identification of data subjects, but without distorting the data processing. The purpose is to provide greater privacy guarantees to individuals, preventing the breach of confidentiality, integrity, and availability of processing systems and services.

Secondly, it states that the aforementioned measures indicated in the informative note constitute an additional precaution to avoid possible accidental dissemination of information and that it is not evidenced that the data were transmitted to a third party but to those interested in the procedure, therefore requesting that the ongoing sanctioning procedure be archived.

In this sense, it should be indicated that the responding entity, in its capacity as a public body responsible for the processing of personal data, should have adopted the necessary measures to prevent any access to the personal information contained in said documentation. Such measures were not fully adopted in the present case, as evidenced by the fact that the Act included

the identifying data of the claimant in this procedure, along with those of other workers.

From all of this, a lack of due diligence is deduced both in the compliance with the established security measures, as well as in the supervision or verification of their observance and/or suitability.

Consequently, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringement declared to have been committed nor do they constitute sufficient justification or exculpation.

IV

Unfulfilled Obligation

The claimed facts materialize in the notification sent on February 25, 2022, by the responding party to B.B.B., a former employee of the company Tapioca Healthy Food, S.L., in which a liquidation record of

contributions (record number 82022008026752 TR) was attached, containing personal data of various individuals, including data of the claimant, which constitutes a violation of the data protection regulations.

It is, therefore, pertinent to analyze whether the processing of personal data carried out through said notification is in accordance with the provisions of the GDPR.

Article 33 of Royal Decree 928/1998, of May 14, which approves the General Regulation on procedures for the imposition of sanctions for social order infringements and for the liquidation files of Social Security contributions establishes, in relation to the notification and resolution of liquidation records, the following:

“1. The liquidation records of contributions shall be notified by the Labor and Social Security Inspectorate to the responsible subject, as well as, where applicable, to the subsidiary or joint responsible parties, informing them that they may submit allegations in the manner established in the previous article within fifteen days from the date of notification. In the case of joint liability, the records shall be processed in the same administrative liquidation file.

The liquidation record shall also be notified to the interested workers; if it affects a group of workers, the notification shall be made to their unitary representation or, failing that, to the first of those affected in alphabetical order of surnames and name. Workers who do not agree with the periods and bases of contributions recorded in the record or with the validity of the liquidation may submit allegations under the same conditions as the presumed responsible party. Furthermore, the record shall be communicated immediately to the General Treasury of the Social Security.

Before the expiration of the period indicated for submitting allegations, the interested parties may pay the amount of the debt indicated in the liquidation record, justifying the payment before the Labor and Social Security Inspectorate within the same period. The provisional liquidation amount that has been paid by the responsible subject shall acquire the status of definitive liquidation.”

Regarding the liquidation records, Article 32.1 of the General Regulation on procedures for the imposition of sanctions for social order infringements and for the liquidation files of Social Security contributions provides that “the liquidation records” shall contain the following requirements:

(...)

b) Name and surname or corporate name, address, activity, national identity document or tax identification number, the Social Security contribution account code and, where applicable, the identification number of the Special Regime for Self-Employed Workers, of the responsible subject or subjects.

(...)

d) The data that have served as the basis for calculating the debt: period of default, nominal relationship and contribution group of the affected workers or, where applicable, relationships contained in the official declarations made by the presumed responsible party, sufficiently identifying reference of the content of such declarations, or nominal relationships and data provided and signed by the responsible subject; bases and contribution rates applied; and any other data that the acting official may obtain or deduce for the indicated purposes.”

From the documentation in the file, it is noted that, of all those affected, B.B.B. heads the list of interested parties in alphabetical order of surnames.

Regarding the processing of the data associated with the Record, the responding party states, in response to the request made in the context of the preliminary proceedings, that anonymization is carried out in accordance with the guidelines on data anonymization contained in the informative note from the General Subdirector of Institutional Relations and Technical Assistance of the State Agency for Labor and Social Security Inspection, sent to the Provincial Inspections on 11/22/21, and automatically incorporated into the corresponding computer application.

This note states verbatim:

“However, given the requirements of both the LOPDP for data protection and the requirements regarding the content of the liquidation records provided by the General Regulation on procedures for the imposition of sanctions for social order infringements and for the liquidation files of Social Security contributions, it is considered that compliance with both regulations is possible provided that:

a) In the body of the liquidation records, all personal data, both of the affected workers and of any

other natural person whose testimony has been taken into account or is included in the account of the facts, is 'anonymized', in accordance with the provisions of point III of this note (this task must be performed by the acting official).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/19

a) Two models of nominal lists of workers affected by the liquidation act shall be prepared, one that will include all data of the affected workers to prevent the responsible party from being left defenseless, and another, anonymized in accordance with point III* of this note, which will be sent to the other parties distinct from the company as provided by Article 33.1. (In this case, the personal data of the NIF/NIE/Passport and NAF will be anonymized as specified in point III)."

Well, transferring these considerations to the specific case being examined, a copy of the Act sent to the workers and provided by both the claiming party and the responding party is available, which contains, without anonymization, on page 22: the name, surname, and DNI of the claimant, as interviewed by the labor inspector along with the data of four other individuals, and on page 24: name and surname, night hours worked during the period, and total amount owed for several workers, including the claimant. This means that the document is not anonymized, containing references that allow for the identification of the claiming party.

At the end of the Act, a nominal list of workers is attached with the data of the Affiliation Number (NAF) and DNI, both partially anonymized, name and surname along with contribution data.

In this regard, we must recall the definition of personal data contained in Article 4 of the GDPR: "... 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person..."

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.

Furthermore, "processing" should be understood as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction."

V

Duty of confidentiality.

Article 5.1.f) of the GDPR establishes the following:

"Article 5 Principles relating to processing:

1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

In relation to this principle, Recital 39 of the aforementioned GDPR states that:

"[...] Personal data must be processed in a manner that ensures appropriate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and of the equipment used for processing."

The documentation in the file provides clear evidence that the respondent violated Article 5.1 f) of the GDPR, principles relating to processing.

In this case, it is noted that the personal data of the claiming party, contained in the act, were

improperly disclosed to the other workers providing services in the company, violating the principle of confidentiality.

In the copy of the Act sent to the workers and provided by both the claiming party and the responding party, it contains, without anonymization, on page 22: the name, surname, and DNI of the claimant, as interviewed by the labor inspector along with the data of four other individuals, and on page 24: name and surname, night hours worked during the period, and total amount owed for several workers, including the claimant. This document is not fully anonymized, containing references that allow for the identification of the claiming party.

At the end of the Act, a nominal list of workers is attached with the data of the Affiliation Number (NAF) and DNI, both partially anonymized, name and surname along with contribution data.

Consequently, it is considered that the established facts constitute an infringement, attributable to the responding party, for violation of Article 5.1.f) of the GDPR.

VI

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes one of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/19

a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VII

Data Security.

Article 32 of the GDPR establishes the following regarding the security of processing:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/19

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the data controller or the data processor and having access to personal data may only process such data in accordance with the instructions of the data controller, unless required to do so by Union law or the laws of the Member States.

From the documentation in the file, there is clear evidence that the respondent has violated Article 32 of the GDPR, as a security incident occurred by disclosing personal information and data to third parties, by notifying a settlement report that contained personal data without anonymization.

In this regard, the content of the documentation submitted by the respondent indicates the obligation to anonymize all personal data in the body of the settlement reports, both of the affected workers and of any other natural person whose testimony has been considered or is included in the account of the facts and the preparation of two models of nominal lists of workers affected by the settlement report, one that will include all personal data of the affected workers that prevents the responsible party from being left defenseless, and another, anonymized, which will be sent to the other parties outside the company as provided for in Article 33.1.

However, this document is not fully anonymized, containing references that allow the identification of the claimant. This statement highlights the lack of knowledge of the personnel involved in the process regarding the anonymization of the data.

In this sense, it is important to emphasize that data will be considered anonymized to the extent that there is no reasonable probability that any person can identify the natural person within the dataset.

The purpose of the anonymization process is to eliminate or minimize the risks of re-identification of the data subjects, but without distorting the data processing. The aim is to provide greater privacy guarantees to individuals, preventing the violation of the confidentiality, integrity, and availability of the processing systems and services. In the present case, the personal data of the claimant is not correctly anonymized, allowing it to be identifiable to individuals who are aware of the non-anonymized circumstances.

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the data processor shall apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of the technical and organizational measures must be made taking into account: pseudonymization and encryption, the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/19

capacity to ensure confidentiality, integrity, availability, and resilience, the capacity to restore

availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention will be paid to the risks presented by data processing, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial harm.”

The responsibility of the respondent is determined by the breach of technical and organizational measures, as they are responsible for making decisions aimed at effectively implementing the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk to ensure the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

Consequently, it is considered that the established facts constitute an infringement attributable to the entity being claimed, for violation of Article 32 of the GDPR.

VIII

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes one of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

IX

Sanction

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Furthermore, Article 77 “Regime applicable to certain categories of controllers or processors” of the LOPDGDD provides the following:

“1. The regime established in this article shall apply to the processing for which they are responsible or

processors:

(...)

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/19

The resolution will be notified to the responsible party or data processor, to the hierarchical body to which it depends, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to what is established in the previous section, the data protection authority will also propose the initiation of disciplinary actions when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied will be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the violations are attributable to authorities and executives, and the existence of technical reports or recommendations for processing that have not been duly addressed is proven, the resolution imposing the sanction will include a reprimand naming the responsible position and will order publication in the corresponding Official State or regional Gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article will be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.

In the present case, it is deemed appropriate to sanction the complained party for violation of Article 5.1.f) of the GDPR and for the violation of Article 32 of the GDPR, due to the breach, as a consequence of a lack of due diligence, of the technical and organizational measures that had been implemented, resulting in a breach of the principle of confidentiality. The sanction to be imposed is a warning.

X

The text of the resolution establishes what the violations committed have been and the facts that have led to the breach of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them correspond to the sanctioned party, as it is the data processor who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection

RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/19

FIRST: IMPOSE on the STATE AGENCY FOR LABOR INSPECTION AND SOCIAL SECURITY, with NIF Q2802489A, for violation of Articles 5.1.f) and 32 of the GDPR, classified respectively in sections 5 and 4 of Article 83 of the GDPR, a sanction of warning.

SECOND: NOTIFY this resolution to the STATE AGENCY FOR LABOR INSPECTION AND SOCIAL SECURITY.

THIRD: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and in section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be suspended provisionally if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation evidencing the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-250923

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es